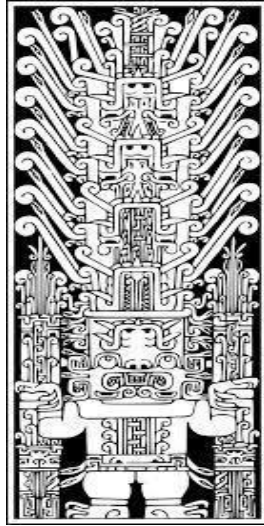


UNIVERSIDAD NACIONAL FEDERICO VILLARREAL
FACULTAD DE INGENIERÍA INDUSTRIAL Y DE SISTEMAS
ESCUELA PROFESIONAL DE INGENIERÍA DE SISTEMAS



INFORME DE XSS EN UN SITIO WEB O ENTORNO LOCAL

AUTOR

Mina Rios Aaron Mark

CURSO

Ciberseguridad

2026

Informe de explotación de vulnerabilidad con XSS

1. Resumen

Durante la evaluación de seguridad de la aplicación web se identificó una vulnerabilidad de tipo Cross-Site Scripting (XSS), la cual permitió la ejecución de código JavaScript dentro del navegador de los usuarios que accedieran al contenido vulnerable.

La vulnerabilidad fue detectada mediante pruebas manuales en campos de entrada de la aplicación, verificando que el contenido ingresado por el usuario era procesado sin una validación o sanitización adecuada.

Hallazgo	Vector	Severidad	Impacto
Cross-Site Scripting (XSS)	Campo de búsqueda/comentarios	Alta	Ejecución de código en navegador
Falta de validación de entradas	Formularios web	Alta	Inyección de scripts maliciosos
Ausencia de filtrado HTML	Aplicación web	Media	Manipulación del contenido mostrado

2. Alcance de la Evaluación

Elemento	Descripción
Tipo de evaluación	Web Application Penetration Test
Metodología	CEH - Web Application Security
Vulnerabilidad evaluada	Cross-Site Scripting (XSS)
Entorno	Laboratorio controlado / OWASP Juice Shop

3. Metodología

La evaluación siguió las siguientes etapas:

3.1 Reconocimiento

Se identificaron los campos de entrada de la aplicación susceptibles de recibir contenido proporcionado por el usuario, tales como:

- Formularios de comentarios.
- Campos de búsqueda.
- Parámetros URL.
- Formularios de contacto.

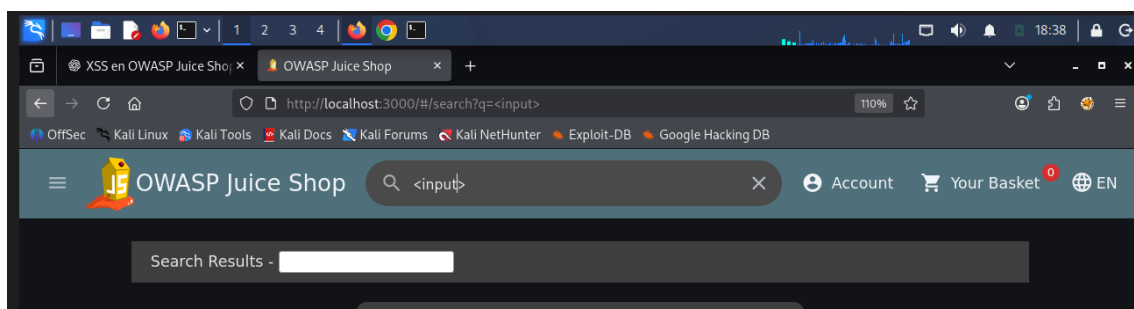
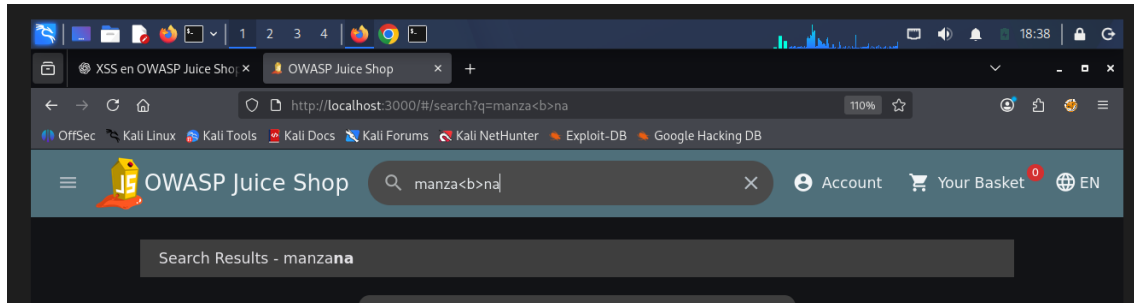
Posteriormente se verificó si la aplicación reflejaba el contenido ingresado sin realizar procesos de validación o codificación.

3.2 Identificación de la Vulnerabilidad

Durante las pruebas se ingresaron cadenas de prueba que contenían etiquetas HTML y código JavaScript.

Se observó que la aplicación procesaba y mostraba parte del contenido suministrado por el usuario sin aplicar mecanismos adecuados de sanitización.

Este comportamiento constituye un indicador típico de una vulnerabilidad Cross-Site Scripting (XSS).



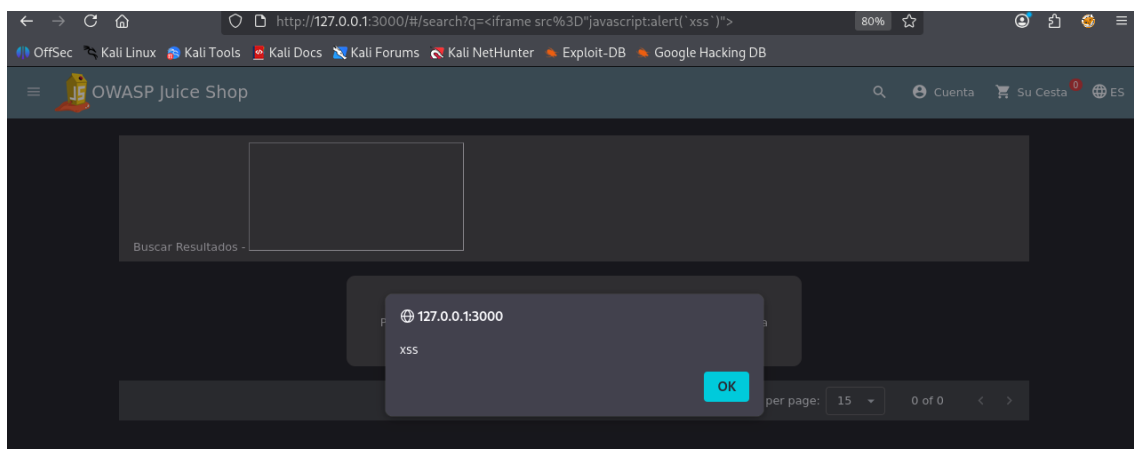
3.3 Explotación

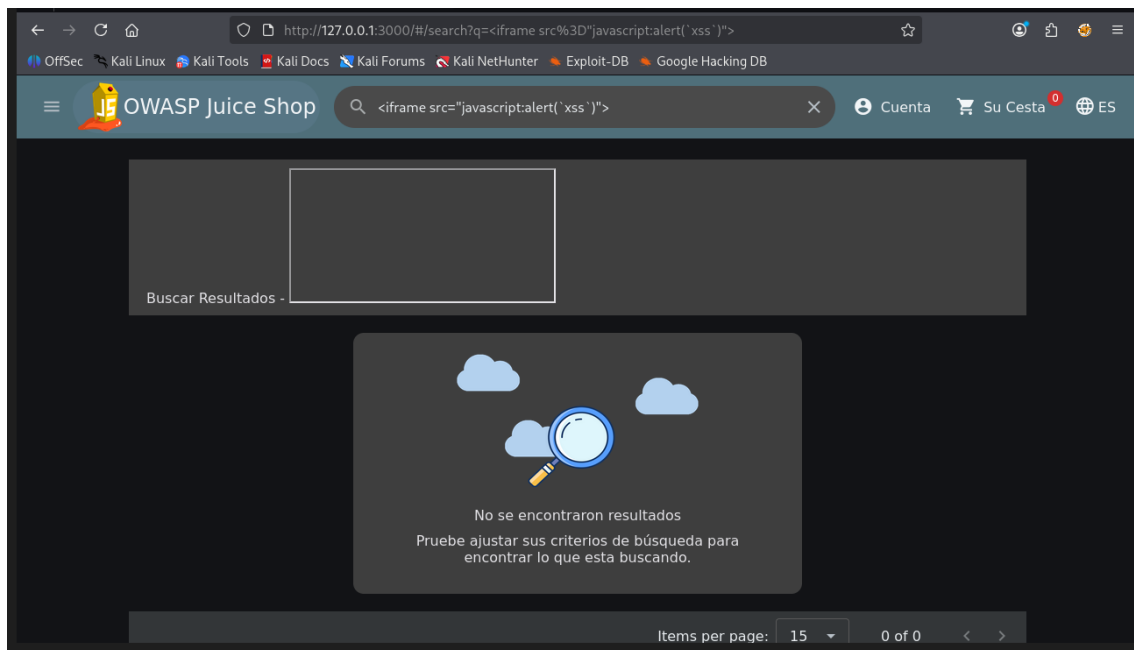
Una vez identificado el comportamiento vulnerable, se realizaron pruebas controladas para verificar la ejecución de código JavaScript en el navegador.

La aplicación permitió la carga de contenido HTML embebido, demostrando la posibilidad de ejecutar scripts dentro del contexto del sitio web.

Como evidencia, se observó la ejecución del contenido inyectado y la modificación dinámica de elementos de la página.

<iframe src="javascript:alert(xss)">





Este payload fue utilizado para verificar si la aplicación permitía la inserción y ejecución de código JavaScript dentro del navegador del usuario.

La etiqueta `<iframe>` intenta cargar una dirección utilizando el esquema `javascript:`, lo que provoca la ejecución de una instrucción JavaScript cuando el navegador procesa el contenido.

En este caso, la función `alert()` genera una ventana emergente, utilizada comúnmente como prueba de concepto para demostrar la existencia de una vulnerabilidad Cross-Site Scripting (XSS) sin causar daños al sistema.

Resultado esperado

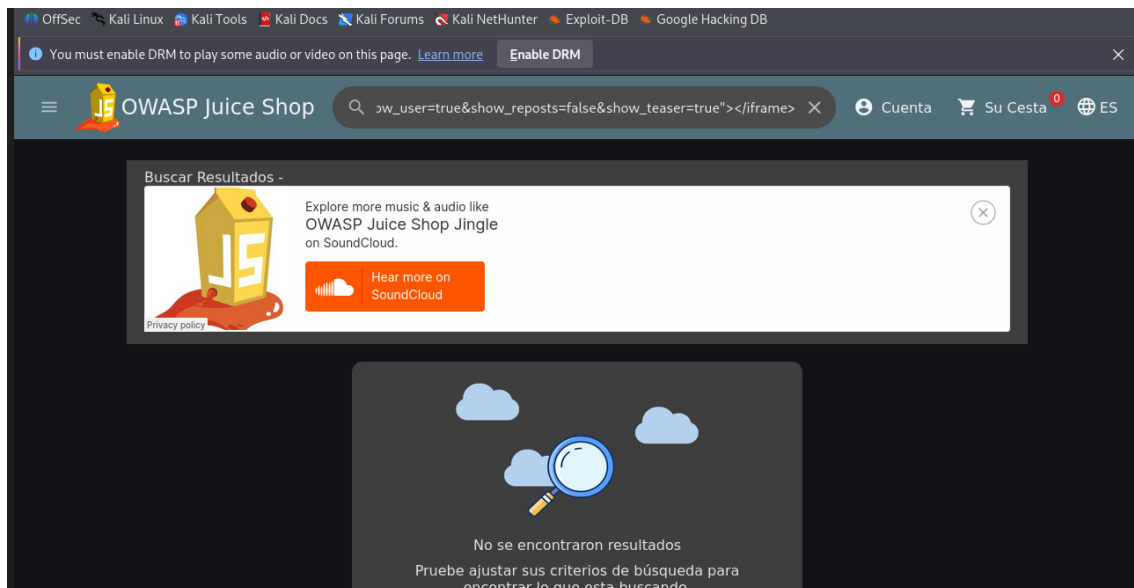
Si la aplicación es vulnerable, el navegador ejecutará el código JavaScript y mostrará una ventana emergente indicando que el script fue ejecutado exitosamente.

Impacto potencial

La ejecución exitosa de este tipo de código podría permitir a un atacante:

- Ejecutar scripts arbitrarios en el navegador de la víctima.
- Manipular el contenido visualizado.
- Capturar información sensible.
- Robar cookies de sesión.
- Realizar acciones en nombre del usuario autenticado.

```
<iframe width="100%" height="166" scrolling="no" frameborder="no" allow="autoplay"
src="https://w.soundcloud.com/player/?url=https%3A//api.soundcloud.com/tracks/771984
076&color=%23ff5500&auto_play=true&hide_related=false&show_comments=true&show_
user=true&show_reposts=false&show_teaser=true"></iframe>
```



Este payload fue utilizado para verificar si la aplicación permitía la inserción de elementos HTML embebidos sin aplicar mecanismos adecuados de filtrado o sanitización.

La etiqueta `<iframe>` carga contenido externo desde la plataforma SoundCloud, incrustando un reproductor de audio dentro de la página vulnerable.

Si la aplicación permite la inserción de HTML sin restricciones, el reproductor de audio aparecerá y será funcional dentro de la página web.

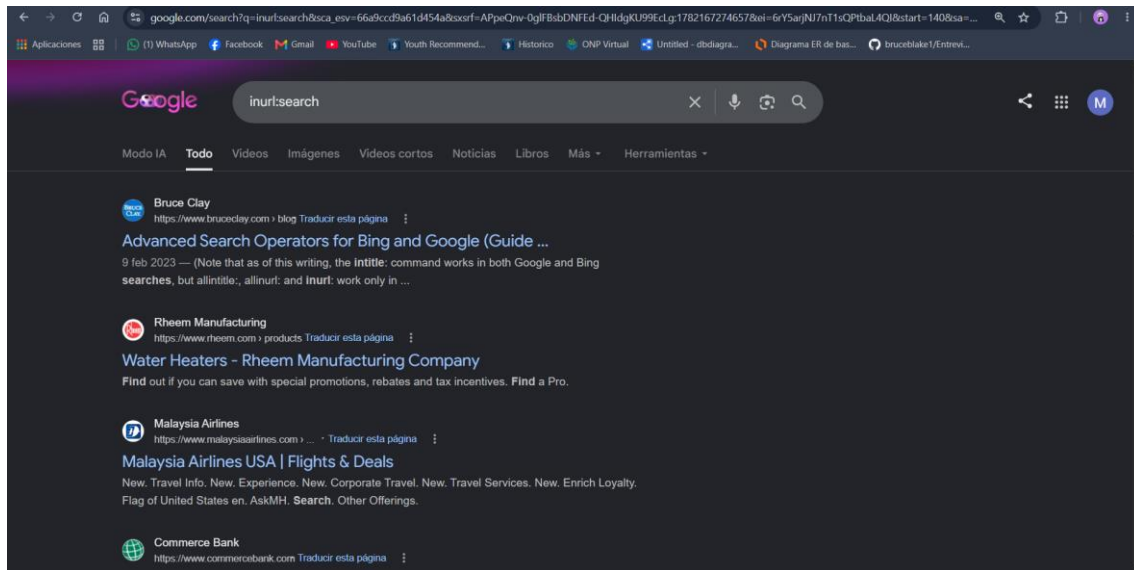
Riesgo de seguridad:

Aunque este código no ejecuta JavaScript malicioso directamente, demuestra que la aplicación acepta etiquetas HTML potencialmente peligrosas.

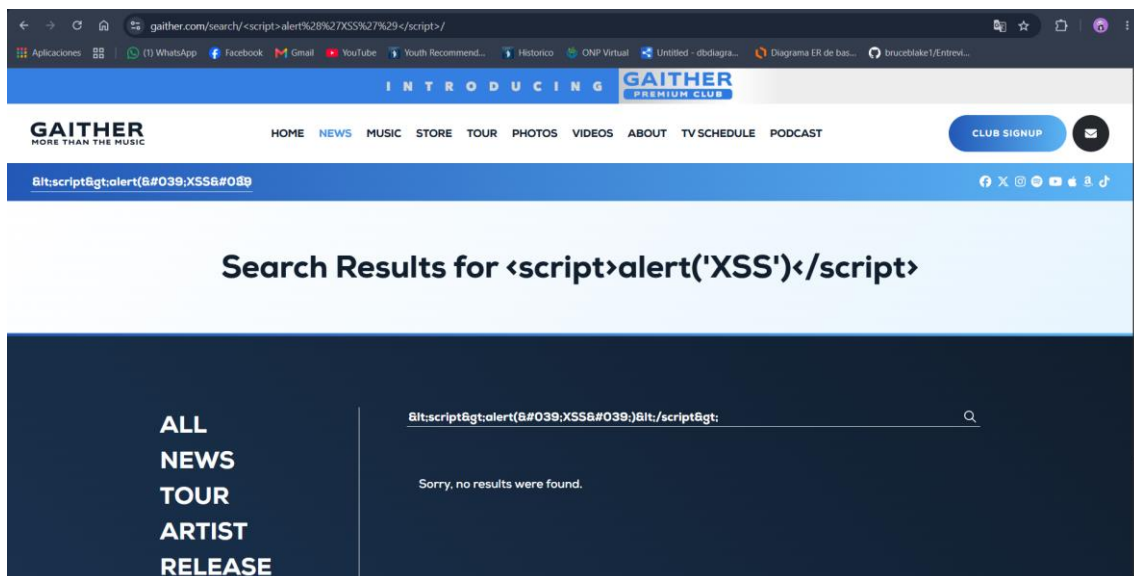
Formas de aprovechar este comando:

- Insertar contenido fraudulento.
- Mostrar formularios falsos de autenticación.
- Realizar ataques de phishing.
- Cargar contenido externo controlado por el atacante.
- Preparar escenarios para ataques XSS más avanzados.

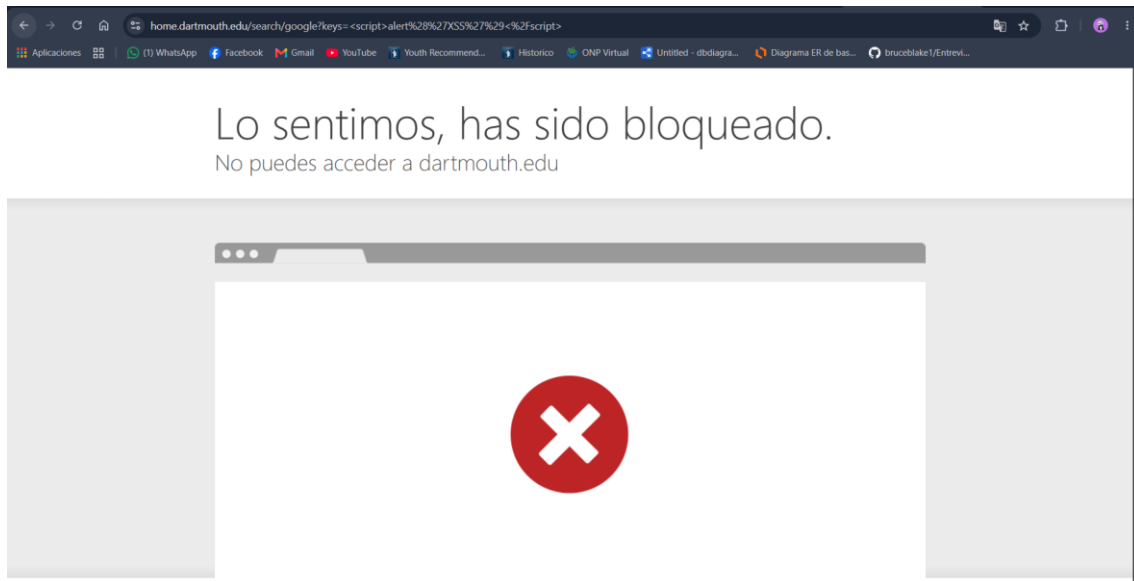
Identificar vulnerabilidades de XSS en páginas web:



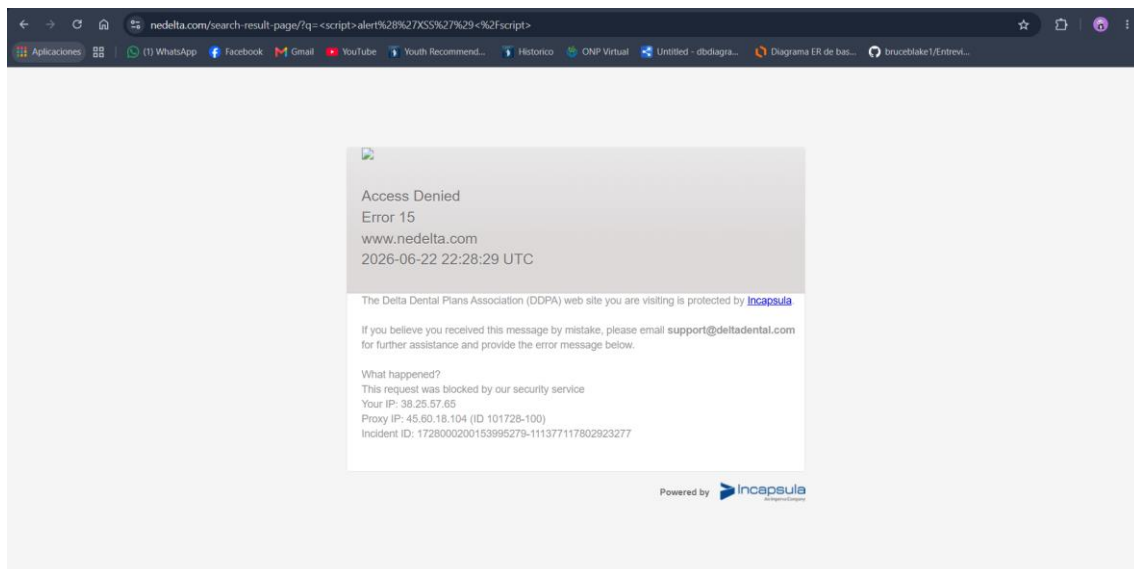
Gaither:



Dartmouth:



Nedelta.com:



3.4 Resultado de la Explotación

La ejecución satisfactoria del código confirmó la existencia de la vulnerabilidad XSS.

Un atacante podría aprovechar esta condición para:

Manipular el contenido visualizado por los usuarios.

Ejecutar código JavaScript arbitrario.

Robar información de sesión.

Realizar acciones en nombre del usuario autenticado.

Redirigir usuarios a sitios maliciosos.

4. Hallazgos y Priorización

4.1 Hallazgo Crítico: Cross-Site Scripting (XSS)

La aplicación permite la ejecución de código JavaScript suministrado por el usuario sin una validación adecuada.

Impacto:

Compromiso de la sesión del usuario.

Robo de cookies.

Modificación del contenido mostrado.

Suplantación de identidad.

4.2 Hallazgo Alto: Falta de Sanitización de Entradas

Los datos recibidos por la aplicación son procesados sin eliminar etiquetas HTML o caracteres potencialmente peligrosos.

4.3 Hallazgo Medio: Ausencia de Codificación de Salida

La aplicación no implementa mecanismos de Output Encoding antes de mostrar la información al usuario.

5. Impacto

La explotación exitosa de la vulnerabilidad podría permitir:

- Robo de credenciales.
- Secuestro de sesiones.
- Redirección a sitios fraudulentos.
- Distribución de malware.
- Pérdida de confianza en la aplicación.
- Incumplimiento de políticas de seguridad.

6. Recomendaciones

Vulnerabilidad	Recomendación	Prioridad
XSS	Validar y sanitizar todas las entradas de usuario	Inmediata
XSS	Aplicar Output Encoding antes de mostrar datos	Inmediata
XSS	Implementar Content Security Policy (CSP)	Alta
XSS	Utilizar bibliotecas de sanitización seguras	Alta
XSS	Realizar pruebas periódicas de seguridad	Media

Sanitización de Entradas

Todos los datos proporcionados por los usuarios deben ser filtrados antes de ser almacenados o procesados por la aplicación.

Content Security Policy (CSP)

Se recomienda implementar políticas CSP para restringir la ejecución de scripts no autorizados.

Codificación de Salida

Todo contenido dinámico debe codificarse antes de mostrarse en el navegador para evitar la interpretación de código HTML o JavaScript